# Auditoria Técnica de Software

ELCOP - Gestao de TI

**7.2/10**

Nota geral do projeto

**Repositório:** https://github.com/RodrigoTabaldi/sistemagestaoTI
**Stack identificada:** C# / .NET 10, ASP.NET Core MVC, Entity Framework Core, ASP.NET Identity, SQLite / SQL Server / PostgreSQL, Firebase opcional
**Linhas de código (aprox.):** 18026
**Data da análise:** 26/08/2026
**Realizado por:** Codex - Auditoria de Engenharia Senior

# Sumário Executivo

O ELCOP - Gestao de TI e uma aplicacao corporativa jovem, mas tecnicamente mais madura do que a maioria dos projetos de portfolio. A separacao em Domain, Application, Infrastructure e Web e coerente; regras relevantes estao em servicos testaveis; ha auditoria, concorrencia otimista de ativos, paginacao, cache, protecao contra mass assignment, validacao de upload e uma pipeline que compila com warnings como erros, valida migrations, executa testes, mede cobertura e audita dependencias. A suite atual executou 81 testes com sucesso e a consulta ao NuGet nao encontrou pacotes vulneraveis nem atualizacoes pendentes nas fontes configuradas.

O maior salto agora nao e adicionar telas aleatorias. Para sustentar a afirmacao de que o sistema esta pronto para uso empresarial, e preciso proteger fotos e anexos que hoje podem ser servidos fora da autorizacao da aplicacao, revogar imediatamente sessoes de usuarios desabilitados e validar a posse do e-mail se o autocadastro local for habilitado. Tambem vale decidir explicitamente se solicitantes comuns podem consultar todas as demandas ou apenas as proprias.

Para impressionar em um processo interno, o projeto precisa virar um produto demonstravel: ambiente publicado, dados ficticios reproduziveis, deploy automatizado, video curto, diagrama de arquitetura e uma narrativa de impacto mensuravel. A melhor apresentacao e mostrar um fluxo completo - entrada de ativo, entrega por QR code, abertura de demanda, atendimento dentro do SLA e relatorio gerencial - e explicar as decisoes de seguranca e operacao por tras dele.

## Painel de notas por dimensão

| Dimensão | Nota |
|---|---|
| Arquitetura | **8.2/10** |
| Qualidade de Codigo | **7.8/10** |
| Debito Tecnico | **6.2/10** |
| Seguranca | **6.5/10** |
| Performance | **7.2/10** |
| Testes | **7.1/10** |
| Dependencias | **8.8/10** |

# Arquitetura

A solucao possui fronteiras claras. Domain concentra entidades e enums; Application contem casos de uso e contratos; Infrastructure implementa persistencia, Identity, Firebase e armazenamento; Web concentra MVC e composicao. As dependencias apontam para dentro e os servicos usam IAppDbContext e IArmazenamentoArquivos, o que facilita testes e troca de infraestrutura. A configuracao de migrations fora do startup de producao, health checks separados e suporte a tres bancos mostram boa consciencia operacional.

O principal risco arquitetural esta na geracao de codigos por contagem seguida de consulta. Indices unicos preservam integridade, mas requisicoes concorrentes podem calcular o mesmo valor e uma delas falhar. Para um estoque usado por varios tecnicos, a sequencia deve ser responsabilidade transacional do banco ou ter retry explicito.

| Severidade | Achado | Local | Recomendação |
|---|---|---|---|
| MEDIO | Codigos sequenciais sujeitos a colisao concorrente<br>Protocolos MOV e codigos DEM sao produzidos contando registros e testando disponibilidade antes do insert. Duas requisicoes simultaneas podem escolher o mesmo codigo; o indice unico impede corrupcao, mas nao evita erro para um dos usuarios. | src/Elcop.TI.Application/Services/MovimentacaoService.cs:357; src/Elcop.TI.Application/Services/DemandaService.cs:391 | Usar sequence/identity dedicada por provedor ou capturar violacao unica e repetir a geracao dentro de uma transacao, com teste concorrente. |
| MEDIO | Nao existe artefato de deploy reproduzivel<br>Ha uma boa pipeline de CI, mas somente ci.yml foi encontrado; nao ha Dockerfile, infraestrutura como codigo ou workflow de deploy. O sistema pode compilar, mas o repositorio ainda nao prova como uma versao chega de forma repetivel a homologacao ou producao. | .github/workflows/ci.yml:1; raiz do repositorio | Criar container multi-stage, ambiente de homologacao e CD com aprovacao para producao, migrations em etapa unica e rollback documentado. |

# Qualidade de Codigo

O codigo e legivel, usa nullable, nomes do dominio e comentarios que explicam decisoes. Controllers delegam regras aos servicos e os fluxos sensiveis preservam campos controlados pelo servidor. A compilacao Release passou sem erros e sem warnings.

Ha pequenos sinais de evolucao rapida que devem ser limpos antes de apresentar o repositorio como produto: codigo morto no bootstrap e documentacao divergente da pipeline atual. Sao correcoes simples que aumentam muito a sensacao de acabamento.

| Severidade | Achado | Local | Recomendação |
|---|---|---|---|
| BAIXO | Bootstrap contem ramo inalcançavel e gerador sem uso<br>CriarAdministradorAsync lanca excecao quando a senha esta vazia, mas depois volta a testar a mesma condicao para registrar uma senha gerada. GerarSenhaAleatoria tambem permanece sem chamadas. Isso torna a intencao de seguranca menos clara. | src/Elcop.TI.Infrastructure/Persistence/DbInitializer.cs:103-171 | Remover o ramo e o metodo mortos; manter um unico fluxo: senha obrigatoria fornecida por secret manager. |
| BAIXO | Runbook documenta um gate de cobertura que nao existe mais<br>OPERACAO_PRODUCAO afirma 75% de linhas e 65% de ramos, enquanto a CI atual usa 38% e 21%. Documentacao operacional incorreta prejudica confianca e pode gerar conclusoes erradas em uma revisao. | docs/OPERACAO_PRODUCAO.md:18; .github/workflows/ci.yml:53-55 | Atualizar o runbook e manter o baseline em um unico arquivo/propriedade consumido pela CI e pela documentacao. |

# Debito Tecnico

O projeto tem aproximadamente 18 mil linhas autorais em 161 arquivos versionados, nove commits e um unico contribuidor. O README reduz o risco de transferencia, mas o historico curto e concentrado significa que decisoes importantes ainda dependem do autor.

O repositorio tambem versiona resultados de auditoria, imagens temporarias de renderizacao e PDFs duplicados. Esses arquivos nao pertencem ao produto e tornam revisoes e clones mais ruidosos.

| Severidade | Achado | Local | Recomendação |
|---|---|---|---|
| MEDIO | Historico de Git nao comunica maturidade profissional<br>Mensagens como 'gggg', 'att' e 'commit inteiro' nao explicam intencao, risco ou escopo. Para avaliadores, isso enfraquece a rastreabilidade de uma base que tecnicamente e boa. | historico Git: commits ba6e456, c497b8d e be10051 | Usar commits pequenos e descritivos, pull requests com contexto, issues e Conventional Commits ou um padrao equivalente. |
| BAIXO | Vinte e cinco artefatos gerados estao versionados<br>As pastas tmp e output contem PNGs de QA, JSONs de auditoria e PDFs duplicados acompanhados pelo Git. Isso polui o repositorio e pode expor detalhes internos em um projeto publico. | tmp/**; output/**; .gitignore | Ignorar tmp/ e output/; manter somente um relatorio deliberadamente publicado em docs/ quando houver valor de comunicacao. |
| MEDIO | Bus factor igual a um<br>Todo o historico pertence a um unico autor. Revisao, operacao e conhecimento de dominio dependem da mesma pessoa. | historico Git do repositorio | Pedir code review de um desenvolvedor da empresa, registrar ADRs curtos e transformar o runbook em exercicio de transferencia de conhecimento. |

# Seguranca

A postura geral e boa: autenticacao obrigatoria por fallback, politicas por perfil, antiforgery nos POSTs, rate limiting de autenticacao, lockout, cookies seguros em producao, HSTS, CSP, protecao contra open redirect, assinatura de upload e neutralizacao de formulas em CSV. Nao foram encontrados segredos versionados, SQL dinamico ou dependencias com vulnerabilidades conhecidas.

Os riscos restantes sao concretos e ligados a identidade e dados pessoais. Eles devem ser resolvidos antes de publicar uma demonstracao fora de uma rede controlada.

| Severidade | Achado | Local | Recomendação |
|---|---|---|---|
| ALTO | Fotos e uploads podem contornar a autorizacao da aplicacao<br>No armazenamento local, arquivos ficam em wwwroot/uploads e sao servidos por UseStaticFiles antes da autenticacao. No Firebase, cada objeto recebe PublicRead. Fotos de colaboradores e ativos ficam acessiveis por URL sem que as politicas MVC sejam avaliadas; nomes GUID reduzem enumeracao, mas nao tornam o dado privado. | src/Elcop.TI.Web/Program.cs:181; src/Elcop.TI.Infrastructure/Storage/ArmazenamentoFirebase.cs:35-46 | Armazenar objetos de forma privada e servir por endpoint autorizado ou URL assinada de curta duracao; definir retencao e consentimento para fotos de colaboradores. |
| ALTO | Desabilitar usuario nao revoga a sessao ativa<br>UsuariosController altera Habilitado e perfis, mas nao atualiza o security stamp nem existe validacao de principal que rejeite Habilitado=false. Um usuario ja autenticado pode continuar usando o cookie de 10 horas, com renovacao deslizante, mesmo depois de ser desativado. | src/Elcop.TI.Web/Controllers/UsuariosController.cs:124-149,171-186; src/Elcop.TI.Web/Program.cs:48-60 | Atualizar o security stamp em mudancas de acesso e configurar OnValidatePrincipal para rejeitar imediatamente contas desabilitadas; adicionar teste de integracao com cookie real. |
| MEDIO | Autocadastro local confia no endereco de e-mail sem provar posse<br>O cadastro por senha grava EmailConfirmed=true sem enviar token. A producao padrao desabilita o recurso, mas, se autocadastro e aprovacao automatica forem habilitados, qualquer pessoa pode alegar um endereco do dominio permitido e entrar como Consulta. | src/Elcop.TI.Web/Controllers/ContaController.cs:77-129 | Exigir confirmacao de e-mail por token, integrar ao SSO corporativo ou remover o cadastro por senha e manter somente provisionamento administrativo/Firebase validado. |

| Severidade | Achado | Local | Recomendação |
| --- | --- | --- | --- |
| MEDIO | Demandas sao visiveis a qualquer usuario autenticado<br>Index, Quadro e Detalhes dependem apenas da fallback policy e consultam a base inteira. Isso pode ser intencional, mas chamados de TI frequentemente contem nomes, problemas de acesso e detalhes de equipamentos. A regra de privacidade nao esta expressa em politica nem em filtro por solicitante. | src/Elcop.TI.Web/Controllers/DemandasController.cs:31-64; src/Elcop.TI.Application/Services/DemandaService.cs:28-75 | Decidir com a empresa: Tecnico/Admin veem tudo; Consulta ve somente demandas proprias ou explicitamente compartilhadas. Codificar e testar essa regra. |

# Performance

Listagens usam paginacao e AsNoTracking; exportacoes possuem limite de 10 mil itens; o kanban limita 400 registros; o painel usa cache curto e ha metricas de requisicoes, erros e duracao. Essas escolhas sao adequadas para a fase atual.

Nao ha teste de carga nem baseline de banco, portanto nao e possivel afirmar capacidade. O painel executa varias agregacoes sequenciais e o cache e local ao processo; isso e suficiente para uma instancia, mas deve ser medido antes de escalar.

| Severidade | Achado | Local | Recomendação |
|---|---|---|---|
| MEDIO | Capacidade e consultas criticas nao possuem baseline medido<br>O repositorio nao contem cenario de carga, metas de latencia ou analise de planos. O painel agrega varias tabelas e os filtros com LIKE contendo curinga podem degradar conforme inventario e historico crescem. | src/Elcop.TI.Application/Services/PainelService.cs:72-257; servicos de listagem | Criar massa de 10 mil ativos e 50 mil movimentacoes, medir p95 de painel/busca/exportacao e registrar indices ou busca textual conforme evidencias. |

# Testes

A execucao Release concluiu com 81 testes aprovados: 69 na suite de Application e 12 na suite Web. Existem testes reais de regras de ativo, colaborador, movimentacao, demanda, relatorio, upload, autorizacao e mass assignment. A CI falha em warnings, migrations pendentes, testes, cobertura baixa e vulnerabilidades altas ou criticas.

A cobertura consolidada medida no fluxo do CI e 38,93% de linhas e 21,51% de ramos. O baseline evita queda brusca, mas ainda deixa muitos caminhos sem protecao. A ausencia mais importante nao e quantitativa: os riscos de sessao, cadastro, arquivos privados e concorrencia ainda nao possuem testes.

| Severidade | Achado | Local | Recomendação |
| --- | --- | --- | --- |
| MEDIO | Cobertura de ramos ainda e baixa nos fluxos de maior risco<br>O gate atual aceita 38% de linhas e 21% de ramos. Ha uma boa base de 81 testes, mas cenarios de identidade real, revogacao, armazenamento privado, concorrencia e falha de infraestrutura nao estao cobertos. | .github/workflows/ci.yml:44-55; tests/** | Elevar o gate em passos pequenos e priorizar testes pelos riscos confirmados. Depois adicionar um E2E do fluxo ativo -> entrega -> devolucao e demanda -> atendimento. |

# Dependencias

Todos os projetos usam versoes explicitas e packages.lock.json; o restore da CI e bloqueado; o Dependabot verifica NuGet e GitHub Actions semanalmente; a pipeline gera auditoria de vulnerabilidades. Em 26/08/2026, dotnet package list nao encontrou pacotes vulneraveis nem atualizacoes disponiveis nas fontes configuradas.

Essa e uma das dimensoes mais fortes do projeto. O proximo nivel seria gerar SBOM e assinar o artefato de release, mas nao ha urgencia de atualizacao de bibliotecas no estado auditado.

| Severidade | Achado | Local | Recomendação |
|---|---|---|---|
| INFO | Cadeia de dependencias esta atualizada e auditada<br>NuGet nao reportou vulnerabilidades conhecidas ou versoes mais novas, e o repositorio possui lockfiles, Dependabot e gate de CI. | .github/dependabot.yml:1-13; .github/workflows/ci.yml:57-84 | Manter o processo e acrescentar SBOM CycloneDX/SPDX ao release quando houver deploy automatizado. |

# Produto e Apresentacao

O escopo funcional e forte para uma empresa de engenharia: inventario, colaboradores, localizacoes, movimentacoes, termos, demandas, SLA, kanban, painel, relatorios e auditoria formam uma historia de negocio completa. Para uma vaga interna, o diferencial e mostrar que voce conhece o problema da empresa e mede o resultado, nao apenas que sabe criar CRUD.

A demonstracao deve usar dados ficticios e contar um fluxo de cinco minutos. Comece pelo problema atual, escaneie um QR code de um equipamento, registre a entrega para uma obra/centro de custo, abra uma demanda, mova-a no kanban e finalize com o painel e a trilha de auditoria. Termine com numeros que a empresa poderia acompanhar: ativos sem responsavel, devolucoes em atraso, tempo medio de atendimento e garantias a vencer.

| Severidade | Achado | Local | Recomendação |
|---|---|---|---|
| MEDIO | Falta uma demonstracao reproduzivel e orientada a impacto<br>O README descreve muitas capacidades, mas nao ha ambiente publicado, seed de demonstracao, video curto, diagrama de arquitetura ou roteiro executivo. Um avaliador precisa montar o ambiente para perceber o valor. | README.md; raiz do repositorio | Publicar homologacao com dados ficticios, criar comando de seed/reset, gravar video de 3-5 minutos e incluir arquitetura, screenshots e indicadores de impacto no README. |
| INFO | Ha oportunidades de aderencia especifica a engenharia<br>O modelo atual cobre departamentos e localizacoes, mas pode comunicar ainda mais valor com obra/projeto, centro de custo, inventario por QR code, conciliacao fisica e alertas de contratos/licencas. | modelo de dominio e README.md | Validar com usuarios reais e escolher somente uma entrega de alto impacto: QR code + inventario por obra/centro de custo e uma boa candidata. |

# Roteiro de Recomendações Priorizadas

Ações ordenadas por prioridade, combinando impacto e urgência dos achados de cada dimensão.

| # | Recomendação | Categoria | Esforço | Impacto |
|---|---|---|---|---|
| 1 | Tornar fotos e anexos privados | Seguranca | Medio | Alto - protege dados pessoais e impede acesso fora das politicas |
| 2 | Revogar sessoes ao desabilitar ou rebaixar usuario | Seguranca | Baixo | Alto - torna o controle administrativo efetivo imediatamente |
| 3 | Publicar homologacao com seed e CD | Produto | Medio | Alto - transforma o codigo em demonstracao acessivel e repetivel |
| 4 | Confirmar e-mail ou adotar somente SSO corporativo | Seguranca | Medio | Alto - impede que terceiros aleguem identidades corporativas |
| 5 | Definir privacidade das demandas por perfil e solicitante | Produto / Seguranca | Medio | Alto - alinha o sistema ao tratamento real de chamados internos |
| 6 | Adicionar QR code e recorte por obra/centro de custo | Produto | Medio | Alto - cria um diferencial diretamente ligado a empresa de engenharia |
| 7 | Tornar codigos sequenciais seguros sob concorrencia | Arquitetura | Medio | Medio - evita falhas intermitentes com varios tecnicos |
| 8 | Cobrir fluxos criticos e adicionar um teste E2E | Testes | Medio | Medio - prova qualidade onde o risco e maior |
| 9 | Limpar artefatos, documentacao e historico futuro | Engenharia | Baixo | Medio - melhora muito a leitura por avaliadores e revisores |
| 10 | Medir carga, backup e recuperacao | Operacao | Medio | Medio - demonstra prontidao para dados corporativos reais |

# Apêndice — Metadados do Repositório

| | |
|---|---|
| Nome do projeto | ELCOP - Gestao de TI |
| URL do repositório | https://github.com/RodrigoTabaldi/sistemagestaoTI |
| Stack de linguagens | C# / .NET 10, ASP.NET Core MVC, Entity Framework Core, ASP.NET Identity, SQLite / SQL Server / PostgreSQL, Firebase opcional |
| Linhas de código (aprox.) | 18026 |
| Data da análise | 26/08/2026 |
| Escopo | Leitura dirigida de arquitetura, servicos centrais, Identity, autorizacao, uploads, persistencia, telemetria, CI, documentacao e testes. Arquivos temporarios, bibliotecas vendorizadas, migrations geradas e lockfiles foram excluidos da metrica autoral. |
| Codigo autoral aproximado | 18.026 linhas em 161 arquivos versionados; 8.311 linhas C# de producao sem migrations e 1.628 linhas C# de testes. |
| Historico | 9 commits, 1 contribuidor, atividade entre 12/08/2026 e 26/08/2026. |
| Testes executados | dotnet test Elcop.TI.slnx --configuration Release --no-restore: 81 aprovados, 0 falhas, 0 ignorados. |
| Cobertura medida | 38,93% de linhas e 21,51% de ramos no fluxo configurado com Coverlet. |
| Dependencias | dotnet package list --vulnerable e --outdated: nenhuma vulnerabilidade conhecida e nenhuma atualizacao disponivel nas fontes configuradas em 26/08/2026. |
| CI configurado | GitHub Actions com restore locked, build /warnaserror, validacao de migrations SQLite/PostgreSQL, testes, cobertura e auditoria de vulnerabilidades. |
| Limitacoes | Auditoria estatica dirigida e execucao de testes; nao substitui pentest, teste de carga, revisao LGPD ou validacao com usuarios da empresa. A regra desejada de visibilidade das demandas deve ser confirmada com o negocio. |

*Auditoria pontual do estado local em 26/08/2026. Recomenda-se validar prioridades com TI, RH/LGPD e usuarios de campo antes de implantar em producao.*